DP01 — Data Protection and Retention Policy

[Company] IIoT Platform

Project name: [Company] Security Policies	Status: Active
Date: [Date]	Version: 1.0
Author: [Author Name]	Reviewer: [Reviewer Name]

Versions

Revision	Date	Author	Description
1.0	[Date]	[Author Name]	Initial release

Related Standards, Policies and Processes

- IS01 - [Company] Information Security Policy

Definitions and Terms

Definitions and terms used in this policy follow the SANS Institute Glossary of Security Terms.

Overview

This policy establishes the framework for the protection, retention, and disposal of data within the [Company] IIoT Platform. As data is a critical asset, this document defines the lifecycle management of information to ensure its confidentiality, integrity, and availability, while minimizing risks associated with data breaches or non-compliance.

Purpose

The primary purposes of this policy are to:

- Ensure Compliance: Guarantee adherence to applicable laws, regulations (e.g., GDPR), and contractual obligations regarding data handling.
- Protect Information: Implement safeguards against unauthorized access, accidental loss, or destruction of data.

- Define Retention Periods: Establish clear guidelines on how long different types of data must be kept to meet business and legal requirements.
- Manage Storage: Optimize infrastructure costs and performance by securely disposing of data that is no longer required.

Scope

All employees, contractors, consultants, temporary and other workers of [Company] working on the [Company] IIoT Platform must adhere to this policy. This policy applies to the [Company] platform and its components.

Policy

Data Classification

All data processed by the platform must be classified to determine the appropriate level of protection:

Public: Information intended for public release (e.g., marketing materials, security policies).

Internal: Data for internal business use; unauthorized disclosure is undesirable but not critical (e.g., analytical data).

Confidential: Sensitive data requiring specific protection (e.g., PII, customer data including measurements, configuration details, source code).

Restricted: Highly sensitive data where disclosure could cause severe legal or financial damage (e.g., encryption keys, production credentials).

Classification	Encryption?	MFA Required?	External Sharing?
Public	Optional	No	Allowed
Internal	At Rest	Yes	Partner Only
Confidential	At Rest + Transit	Yes (Phishing Resistant)	**Strictly Prohibited**
Restricted	At Rest + Transit (customer-managed keys)	Yes (Phishing Resistant) + JIT access	Strictly Prohibited

Data Protection Measures

To ensure data security, the following technical measures must be enforced:

Environment Segregation:

Strict segregation between environments must be maintained. Production data is strictly forbidden from being transferred to or processed within non-production environments (e.g., Development, Beta, Staging).

Encryption:

At Rest: All data classified as Confidential or Restricted must be encrypted on all storage media. Encryption should be performed using keys managed by [Company] (Customer Managed Keys) wherever technically possible. Vendor-managed encryption keys are permissible only when [Company]-managed keys are not feasible.

In Transit: Data transmission must use secure protocols (TLS 1.2 or higher).

Access Control:

Access is granted based on the "Least Privilege" principle.

Reviews: Regular access reviews must be conducted to ensure permissions remain appropriate.

Monitoring: Access to Confidential and Restricted data must be strictly monitored and logged to detect anomalies.

Backups:

Validation: Proper training and regular recovery exercises (drills) must be performed to verify backup integrity and recovery procedures.

Storage: Backups must be encrypted and stored in a geographically separate location. They may be stored on-premises or with other cloud vendors, provided that all relevant security regulations and compliance standards are strictly followed.

Data Retention Schedule

Data shall be retained only for as long as necessary. The following standard retention periods apply:

Data Type	Retention Period	Justification
System & Application Logs	90 days (hot storage), 1 year (cold archive)	Incident analysis, security auditing
Database Backups	Daily: 14 days, Weekly: 4 weeks, Monthly: 12 months	Disaster recovery, business continuity
Customer Data (Post-Contract)	30 days (grace period), then permanently deleted	SLA/DPA compliance
CI/CD Artifacts (Builds)	6 months	Release rollback capability
Project Documentation	3 years after project closure	Archival requirements

Data Disposal

Upon reaching the end of the retention period, data must be securely destroyed to prevent recovery (e.g., crypto-shredding, secure overwriting, or physical destruction of media).

Policy Compliance

Compliance Measurement

The Information Security team will verify compliance with this policy through:

Quarterly audits of access controls and encryption configurations.

Verification of backup drills and training logs.

Automated monitoring of environment data flows to ensure production data isolation.

Exceptions

Any exception to this policy must be documented and approved in writing by the Data Protection Officer (DPO) or the Information Security Manager. The exception request must include a business justification, risk assessment, and validity expiration date.

Non-Compliance

An employee found to have violated this policy may be subject to disciplinary action.